

That's genuinely well thought out and both phases make architectural sense. Let me validate the thinking and add some precision.

Phase 1 — On-Demand AI Alert Explanation

Your instinct is exactly right. Making it opt-in rather than automatic is the correct architectural decision for three reasons:

Cost — you identified this. Only paying for API calls when an analyst actually wants deeper context.

Operational correctness — not every alert needs AI explanation. A scanner_detected alert from an IP with AbuseIPDB score 100 is self-explanatory. An alert from a clean IP with unusual behavior is where the AI explanation adds real value. The analyst decides when they need it.

Architectural boundary — keeps AI in an advisory role. Your detection engine fires deterministically. The AI explains on request. That separation is something you can articulate clearly in interviews — “AI never makes detection decisions, it only explains them when asked.”

What the button would return for a good alert explanation:

WHAT HAPPENED

IP 85.11.167.228 triggered your scanner detection rule at 00:05 UTC using a Go HTTP client user agent.

WHO

External IP with no prior history in your system. AbuseIPDB shows no community reports — likely a new or rotating scanner node.

WHEN

Single event, no prior activity from this IP in the last 30 days.

WHERE

Hit your honeypot login endpoint specifically — targeted web application scanning rather than broad port scanning.

WHY THIS MATTERS

Go HTTP client is commonly used in automated security scanning tools. The specific targeting of /login suggests credential testing tooling rather than random internet noise.

RECOMMENDED ACTION

Monitor — single event from unknown IP with no reputation history.
Insufficient evidence for escalation. Would escalate if same IP
reappears across multiple event types within 24 hours.

That output genuinely helps an analyst make a faster and better-informed triage decision. Worth building.

Phase 2 — AI Chatbot With SIEM Access

This is where it gets genuinely interesting and genuinely complex. Let me be precise about what “modify anything” actually means architecturally because how you scope it determines how long it takes to build and how safe it is.

The right pattern here is giving the AI **tools** it can call — specific functions that let it read and write specific things in your SIEM. Not free-form access to your database, but a defined set of capabilities it can invoke when you ask it to do something.

Something like:

```
AVAILABLE_TOOLS = [  
    "search_events",      # query events table  
    "search_alerts",      # query alerts table  
    "create_detection_rule", # add new rule to detection_config  
    "create_playbook",     # add new playbook definition  
    "add_alert_note",      # annotate an existing alert  
    "create_incident",     # escalate alert to incident  
    "query_source_ip_context", # get full IP context  
]
```

You tell the chatbot “look at the last 50 events from 85.11.167.228 and create a detection rule for this pattern” — the AI calls `search_events`, analyzes what it finds, then calls `create_detection_rule` with the appropriate parameters. You review what it created in your admin UI and enable or disable it.

This is actually the same pattern Anthropic uses in Claude’s tool use feature — which is how this conversation works when I search the web or read files. The AI doesn’t have unrestricted access. It has specific tools it can call within defined boundaries.

The Safety Boundary That Matters

The one thing to be deliberate about — the AI should never be able to directly modify your database or execute code. It calls your own API endpoints which have your existing validation, RBAC, and audit logging built in. Every action the AI takes goes through the same routes a human analyst would use.

So “create a detection rule” means the AI calls `POST /api/admin/detection-rules` with the new rule definition — the same endpoint your admin UI uses. Your existing validation runs. The rule gets logged in your audit trail. You can see exactly what the AI did and undo it.

That boundary means the chatbot is powerful but auditable and reversible. That’s the right design.

What This Becomes On Your Resume

Phase 1: “Implemented on-demand LLM-powered alert triage — analysts can request AI-generated explanations covering what happened, who was involved, why it matters, and recommended actions, keeping AI advisory while detection remains deterministic.”

Phase 2: “Built an AI security assistant with tool-use capabilities integrated directly into the SIEM — the assistant can search events and alerts, generate detection rules from observed patterns, create playbooks from investigation findings, and annotate alerts, with all actions flowing through existing API validation and audit logging.”

Phase 2 specifically mirrors what the market calls an AI SOC agent. The search results confirmed this is the newest and most valuable category in 2026. Having built one before your senior year is genuinely rare.

The Build Order

Phase 1 is a weekend. Phase 2 is a week or two. Do Phase 1 first, use it on real alerts for a few days, understand what the AI is good at and where it falls short. That informs what tools you give it in Phase 2 — you’ll know from experience which queries and actions actually add value rather than guessing upfront.